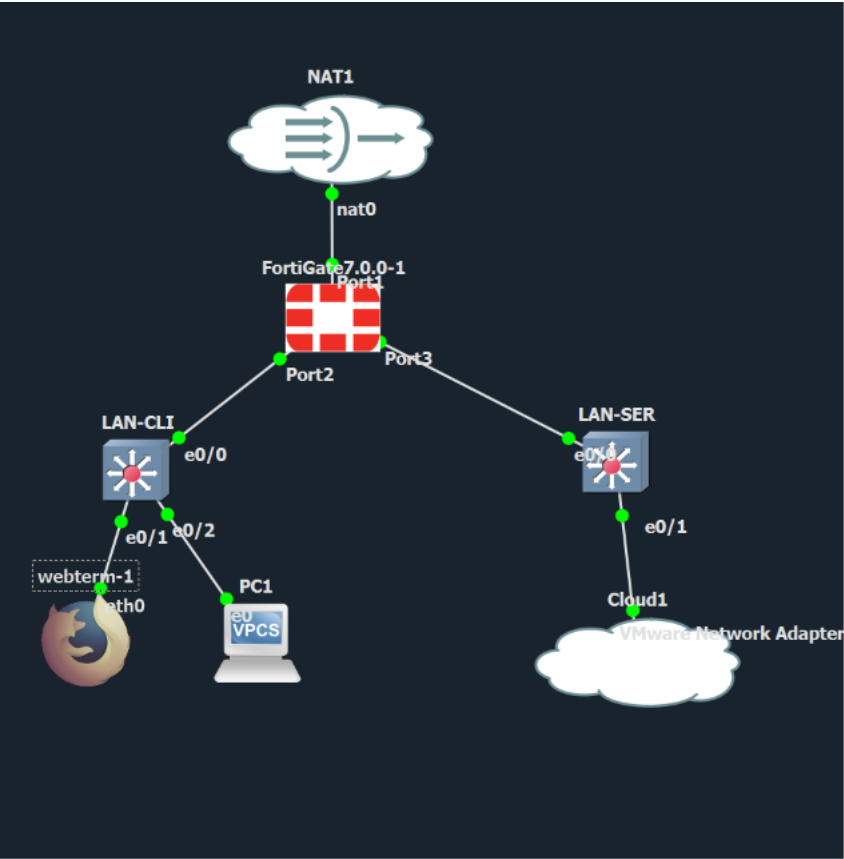


. Objetivo

Implementar, mediante la interfaz gráfica (GUI) de FortiGate, una topología de seguridad perimetral que segmenta una LAN de usuarios y una LAN de servidores provee salida a Internet con NAT, restringe el tráfico entre segmentos al protocolo estrictamente necesario, y aplica controles de filtrado web, control de aplicaciones, prevención de intrusos (IPS) y un Firewall de Aplicaciones Web (WAF) sobre el servidor publicado.

2. Topología de red

La topología fue construida en GNS3 y consta de un FortiGate como frontera de seguridad, un nodo NAT (NAT1) que provee salida real a Internet, dos switches Ethernet (uno por segmento) y los siguientes hosts: un webterm y un VPCS del lado de usuarios, y una VM Kali Linux —actuando como servidor web (Apache)— del lado de servidores.



2.1 Direccionamiento IP

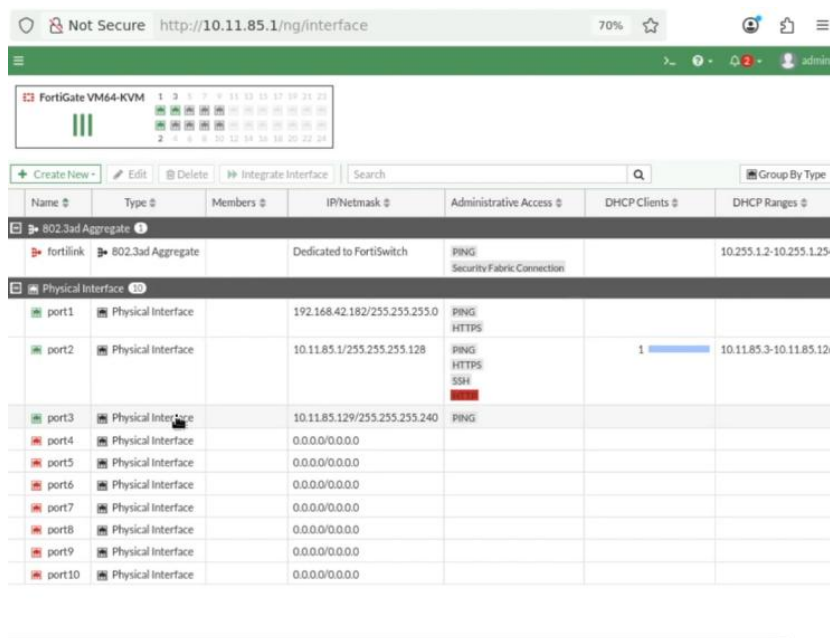
Segmento / Interfaz	Red o IP	Rol
Port1 (WAN)	DHCP (asignado por NAT1)	Salida a Internet
Port2 (LAN-CLIENTE)	10.11.85.1/25	Gateway LAN de usuarios + DHCP server
Port3 (LAN-SERVER)	10.11.85.129/28	Gateway LAN de servidores

Rango DHCP usuarios	10.11.85.3 - 10.11.85.126	Asignado a clientes (PC1)
Servidor Web (Kali)	10.11.85.130/28	IP estática, Apache en puerto 80

3. Configuración del FortiGate

3.1 Interfaces — Network > Interfaces

- Port1: Role WAN · Addressing mode DHCP · Access: PING, HTTPS.
- Port2: Role LAN · Addressing mode Manual · IP/Netmask 10.11.85.1/255.255.255.128 · Access: PING, HTTPS.
- Port3: Role LAN · Addressing mode Manual · IP/Netmask 10.11.85.129/255.255.255.240 · Access: PING.



3.2 DHCP en LAN de usuarios (dentro de Port2)

Address Range: 10.11.85.3 - 10.11.85.126
 Netmask: 255.255.255.128
 Default Gateway: Same as Interface IP
 DNS Server: Specify -> 8.8.8.8

3.3 Ruta por defecto — Network > Static Routes

Destination: 0.0.0.0/0.0.0.0
 Interface: port1
 Gateway: asignado automáticamente por DHCP de NAT1

+ Create New Edit Clone Delete Search				
Destination	Gateway IP	Interface	Status	Comments
IPv4 1				
0.0.0.0/0	Dynamic Gateway (192.168.42.1)	port1	Enabled	

3.4 NAT

Configurado dentro de la política de salida a Internet, mediante Source NAT con "Use Outgoing Interface Address" sobre port1.

3.5 Perfil Web Filter — Security Profiles > Web Filter

Nombre del perfil: Block-Social-ITLA. Se utilizó Static URL Filter (independiente de licencia FortiGuard) para garantizar el bloqueo determinístico de los dominios objetivo:

← → ↺

FortiGate-VM64-KVM

Dashboard

Network

Policy & Objects

Security Profiles

AntiVirus

Web Filter

Video Filter

DNS Filter

Application Control

Intrusion Prevention

File Filter

Web Application Firewall

SSL/SSH Inspection

Application Signatures

IPS Signatures

Web Rating Overrides

Web Profile Overrides

VPN

User & Authentication

System

Security Fabric

Log & Report

Not Secure

http://10.11.85.1/ng/utm/webfilter/profile/edit/Block-Social-ITLA

70%

☆

Edit Web Filter Profile

Log all search keywords

Static URL Filter

Block invalid URLs

URL Filter

+ Create New

Edit

Delete

Search

URL	Type	Action	Status
facebook.com	Wildcard	Block	Enable
*facebook.com	Wildcard	Block	Enable
instagram.com	Wildcard	Block	Enable
*instagram.com	Wildcard	Block	Enable
whatsapp.com	Wildcard	Block	Enable
*whatsapp.com	Wildcard	Block	Enable
*facebook.com	Wildcard	Block	Enable
*instagram.com	Wildcard	Block	Enable
itla.edu.do	Wildcard	Block	Enable

0%

Block malicious URLs discovered by FortiSandbox

Content Filter

Rating Options

Allow websites when a rating error occurs

Rate URLs by domain and IP Address

Additional Information

API Preview

References

Edit in CLI

Documentation

Online Help

Video Tutorials

OK

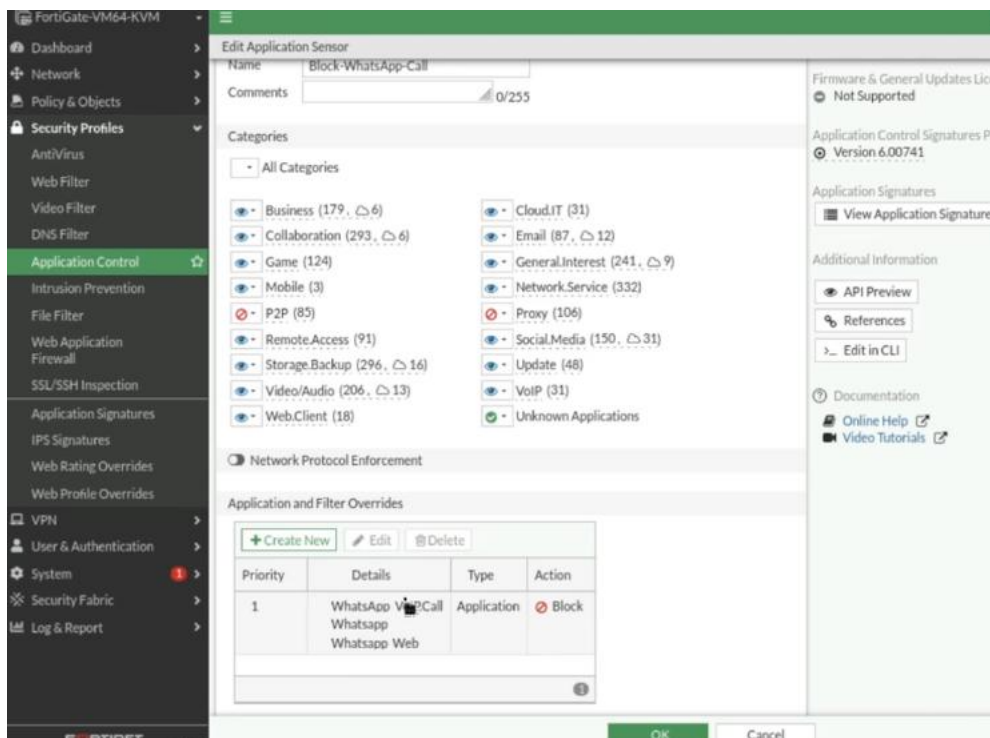
Cancel

URL	Tipo	Acción	Estado
facebook.com	Wildcard	Block	Enable
*.facebook.com	Wildcard	Block	Enable

instagram.com	Wildcard	Block	Enable
*.instagram.com	Wildcard	Block	Enable
whatsapp.com	Wildcard	Block	Enable
*.whatsapp.com	Wildcard	Block	Enable
itla.edu.do	Wildcard	Block	Enable
*.itla.edu.do	Wildcard	Block	Enable

3.6 Application Control — bloqueo de llamadas de WhatsApp

Perfil: Block-WhatsApp-Call. Se agregaron las firmas de voz/video de WhatsApp (WhatsApp.Voice.Call / WhatsApp.Video.Call) con acción Block, dejando la mensajería de texto sin restricción. Adicionalmente se agregó la firma QUIC en Block, ya que Facebook e Instagram reintentan la conexión sobre HTTP/3 (QUIC/UDP) cuando el navegador la soporta, evadiendo así la inspección SSL basada en TCP.



3.7 Intrusion Prevention — detección de escáneres de red

Perfil: Block-Scanners. Se agregaron firmas de la categoría Reconnaissance / Scan (detección de barridos ICMP y escaneo de puertos TCP tipo Nmap) con acción Block.

3.8 Web Application Firewall (WAF)

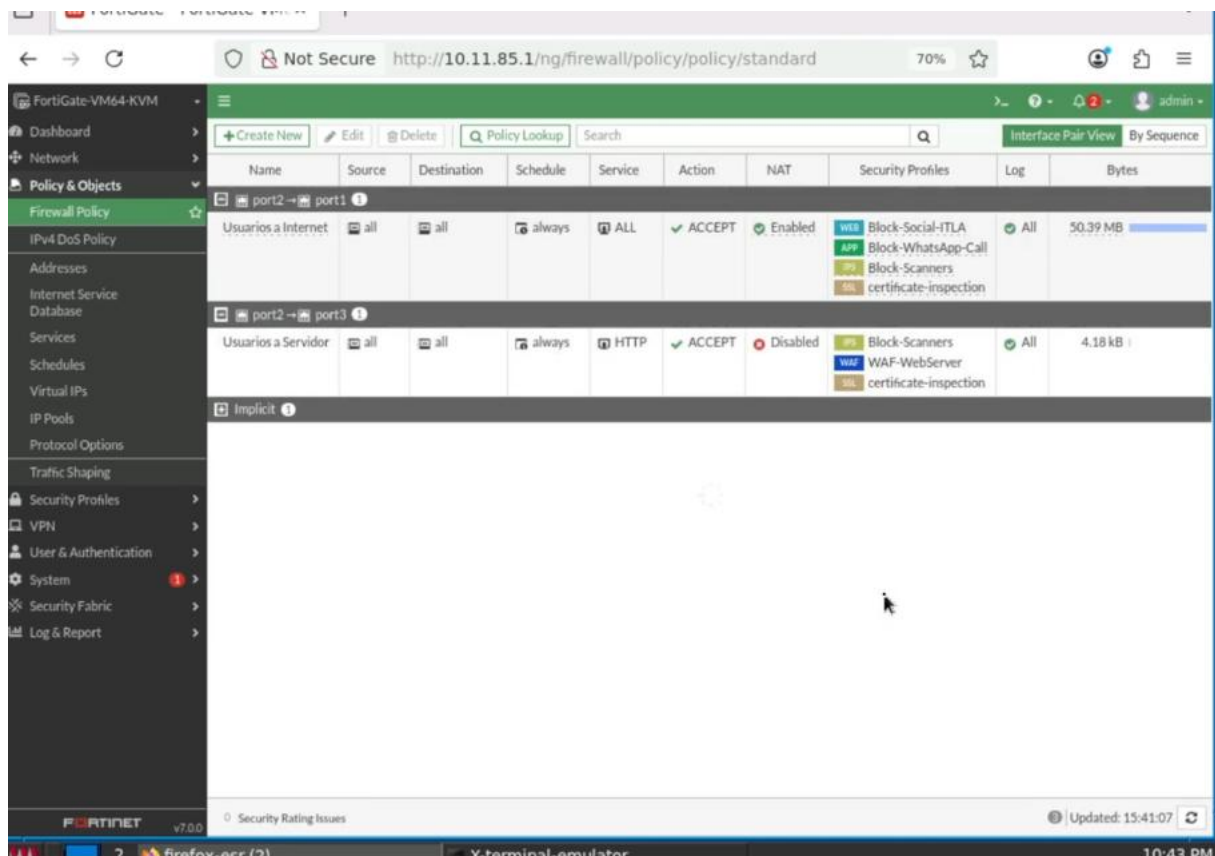
Se habilitó la visibilidad de la función en System > Feature Visibility. Perfil creado: WAF-WebServer, con las firmas de Cross Site Scripting (XSS) y SQL Injection en modo Block, además de las restricciones de protocolo HTTP (HTTP Protocol Constraints) también en Block.

3.9 SSL/SSH Inspection

Se utilizó el perfil certificate-inspection (lectura del SNI en el saludo TLS, sin descifrar contenido), con Inspection Mode de la política en Proxy-based. Este perfil es indispensable para que el Web Filter pueda evaluar tráfico HTTPS; sin él, el FortiGate no puede identificar el dominio solicitado y el filtrado por categoría o URL estática no tiene efecto.

3.10 Políticas de Firewall — Policy & Objects > Firewall Policy

Nombre	In / Out	Servicio	NAT	Perfiles aplicados
Usuarios-a-Internet	port2 / port1	ALL	Enable (SNAT)	Web Filter, App Control, IPS, SSL Inspection
Usuarios-a-Servidor-HTTP	port2 / port3	HTTP	Disable	IPS, WAF



4. Configuración de otros dispositivos

4.1 Switches (LAN-CLIENTE / LAN-SERVER)

No requirieron configuración: todos los puertos permanecieron en VLAN 1 (default), en modo access y sin shutdown.

4.2 Servidor Web (Kali Linux)

```
sudo nano /etc/network/interfaces
auto eth0
iface eth0 inet static
    address 10.11.85.130
    netmask 255.255.255.240
    gateway 10.11.85.129
    dns-nameservers 8.8.8.8
sudo systemctl restart networking
sudo apt update && sudo apt install apache2 -y
sudo systemctl enable apache2 --now
```

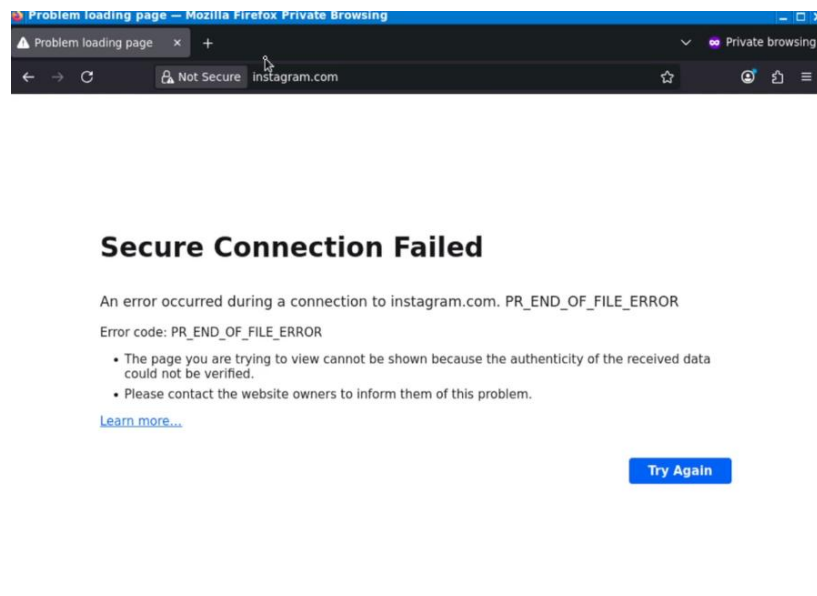
4.3 Cliente / PC1

El webterm obtiene IP automáticamente por DHCP. El VPCS (PC1) se configuró con el comando `ip dhcp`.

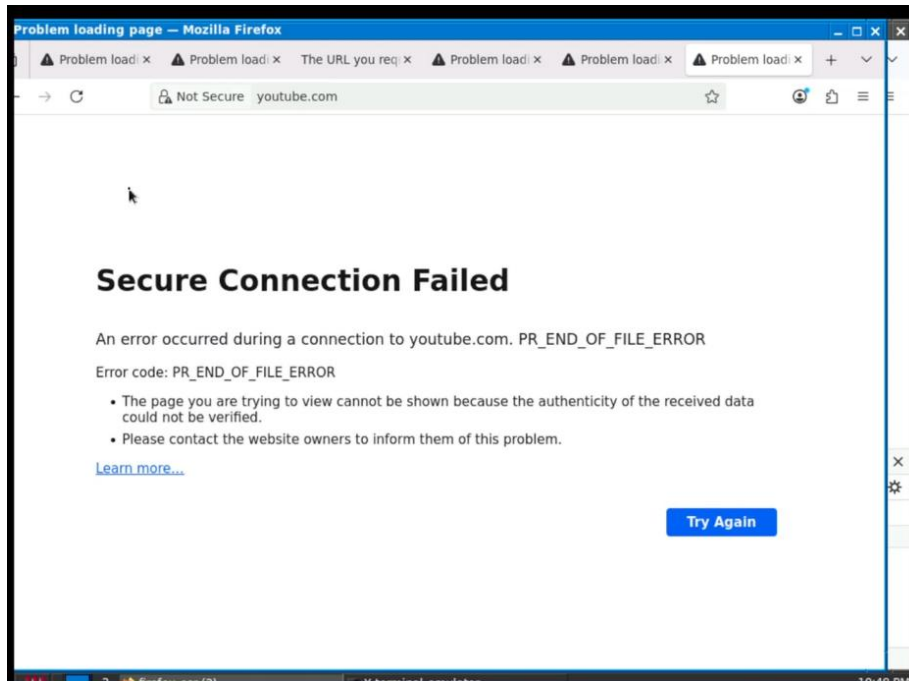
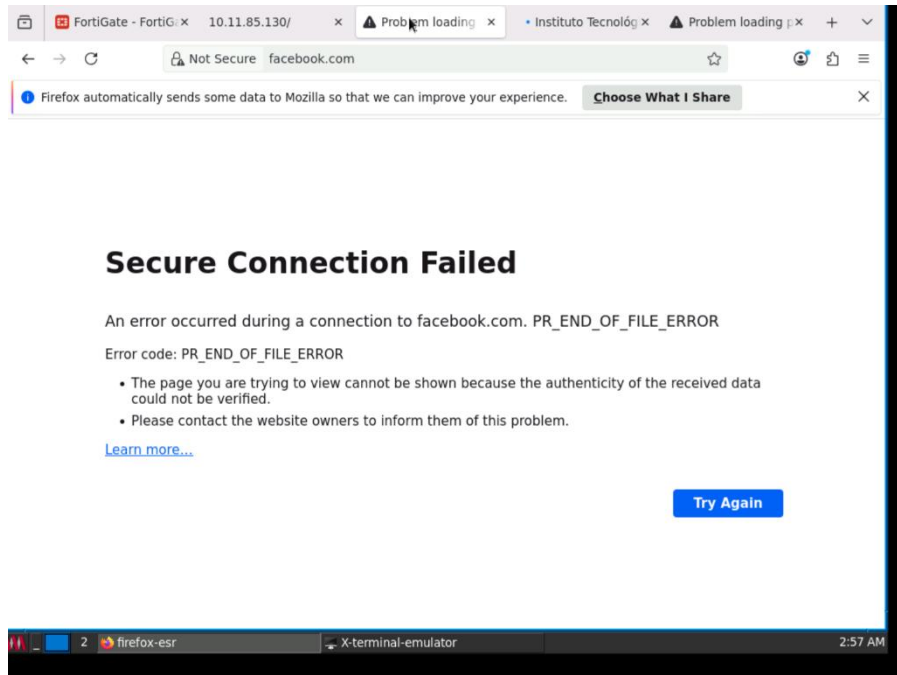
5. Pruebas y evidencia

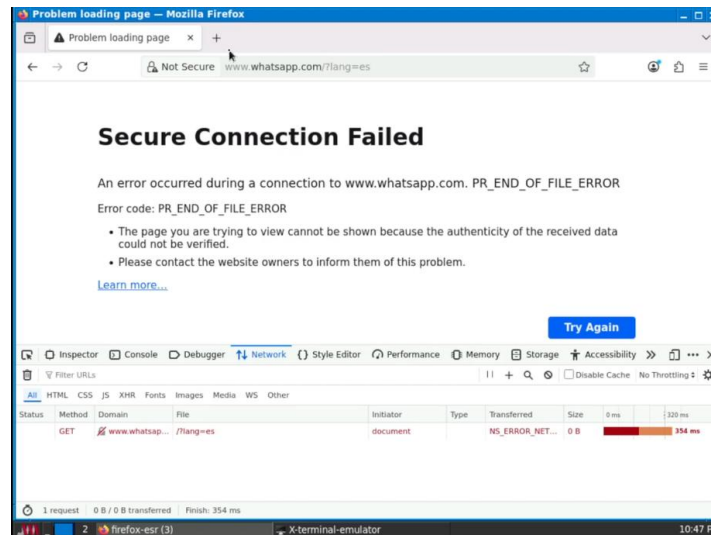
5.1 Bloqueo de redes sociales (HTTPS)

Al intentar acceder a facebook.com desde la LAN de usuarios, la conexión TLS es interrumpida por el FortiGate al detectar el dominio bloqueado vía SNI (certificate-inspection), resultando en un error de conexión segura en el navegador — comportamiento esperado en este modo de inspección.



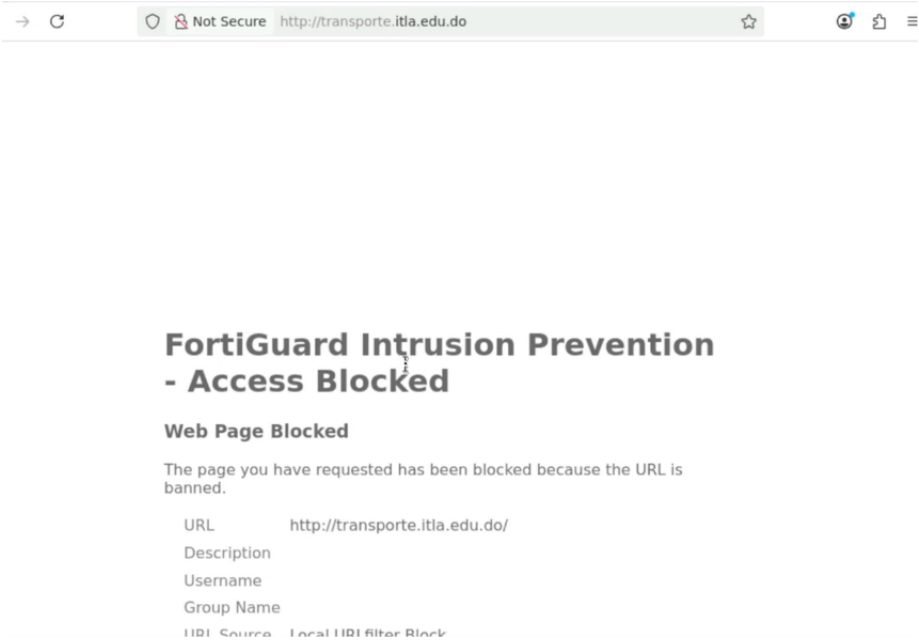
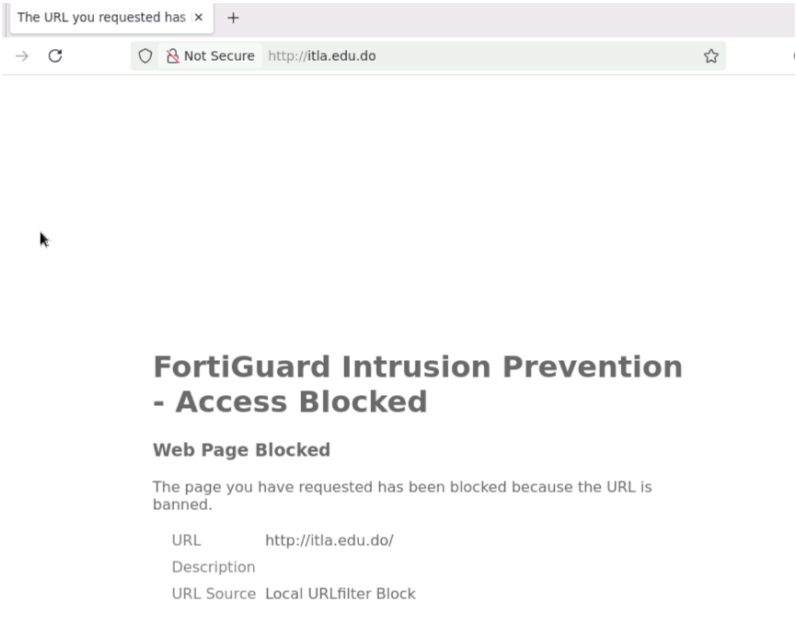
Date/Time		Source	Device	Destination	Application Name	Result	Policy ID
5 minutes ago		10.11.85.2	02:42:87:b4:37:00	57.144.162.34 (instagram.com)		Deny: UTM Blocked	Usuarios a Internet (1
5 minutes ago		10.11.85.2	02:42:87:b4:37:00	57.144.162.34 (instagram.com)		Deny: UTM Blocked	Usuarios a Internet (1
5 minutes ago		10.11.85.2	02:42:87:b4:37:00	57.144.162.34 (instagram.com)		Deny: UTM Blocked	Usuarios a Internet (1
5 minutes ago		10.11.85.2	02:42:87:b4:37:00	8.8.8.8 (dns.google)		64 B / 176 B	Usuarios a Internet (1





5.2 Bloqueo de itla.edu.do y subdominios (HTTP)

Sobre HTTP, el FortiGate identifica el dominio directamente en el header Host y presenta la página nativa de bloqueo de FortiGuard.



FortiGuard Intrusion Prevention - Access Blocked

Web Page Blocked

The page you have requested has been blocked because the URL is banned.

URL http://pagos.itla.edu.do/

Description

Username

Group Name

URL Source Local URLfilter Block

Date/Time	Source	Device	Destination	Application Name	Result	Policy ID
11 minutes ...	10.11.85.2	02:42:b6:0c:a9:00	13.107.253.41 (pagos.itla.edu.do)		Deny: UTM Blocked	Usuarios a Inter
11 minutes ...	10.11.85.2	02:42:b6:0c:a9:00	173.194.212.95 (fonts.googleapis.com)		Deny: UTM Blocked	Usuarios a Inter
11 minutes ...	10.11.85.2	02:42:b6:0c:a9:00	173.194.212.95 (fonts.googleapis.com)		Deny: UTM Blocked	Usuarios a Inter
11 minutes ...	10.11.85.2	02:42:b6:0c:a9:00	173.194.212.95 (fonts.googleapis.com)		Deny: UTM Blocked	Usuarios a Inter
11 minutes ...	10.11.85.2	02:42:b6:0c:a9:00	20.12.97.102 (transporte.itla.edu.do)		Deny: UTM Blocked	Usuarios a Inter
11 minutes ...	10.11.85.2	02:42:b6:0c:a9:00	20.22.31.128 (transporte.itla.edu.do)		Deny: UTM Blocked	Usuarios a Inter
11 minutes ...	10.11.85.2	02:42:b6:0c:a9:00	20.22.31.128 (transporte.itla.edu.do)		Deny: UTM Blocked	Usuarios a Inter
11 minutes ...	10.11.85.2	02:42:b6:0c:a9:00	173.194.212.95 (fonts.googleapis.com)		Deny: UTM Blocked	Usuarios a Inter
11 minutes ...	10.11.85.2	02:42:b6:0c:a9:00	192.178.50.74 (logads-pa.clients6.google.com)		✓ 4.17 kB / 5.20 kB	Usuarios a Inter
11 minutes ...	10.11.85.2	02:42:b6:0c:a9:00	8.8.8.8 (dns.google)		✓ 296 B / 282 B	Usuarios a Inter
11 minutes ...	10.11.85.2	02:42:b6:0c:a9:00	8.8.8.8 (dns.google)		✓ 130 B / 378 B	Usuarios a Inter
11 minutes ...	10.11.85.2	02:42:b6:0c:a9:00	8.8.8.8 (dns.google)		✓ 65 B / 162 B	Usuarios a Inter
11 minutes ...	10.11.85.2	02:42:b6:0c:a9:00	173.194.212.95 (fonts.googleapis.com)		Deny: UTM Blocked	Usuarios a Inter
11 minutes ...	10.11.85.2	02:42:b6:0c:a9:00	173.194.212.95 (fonts.googleapis.com)		Deny: UTM Blocked	Usuarios a Inter
11 minutes ...	10.11.85.2	02:42:b6:0c:a9:00	142.251.157.119 (www.google.com)		✓ 26.59 kB / 1.34 MB	Usuarios a Inter

5.3 Restricción de tráfico entre LAN de usuarios y LAN de servidores

Se verificó que únicamente el tráfico HTTP (puerto 80) hacia el servidor Kali (10.11.85.130) es aceptado; cualquier otro protocolo (ICMP, SSH, escaneos con Nmap) es descartado por el implicit deny.

```

PC1> ip dhcp
DDORA IP 10.11.85.3/25 GW 10.11.85.1

PC1> ping 10.11.85.130

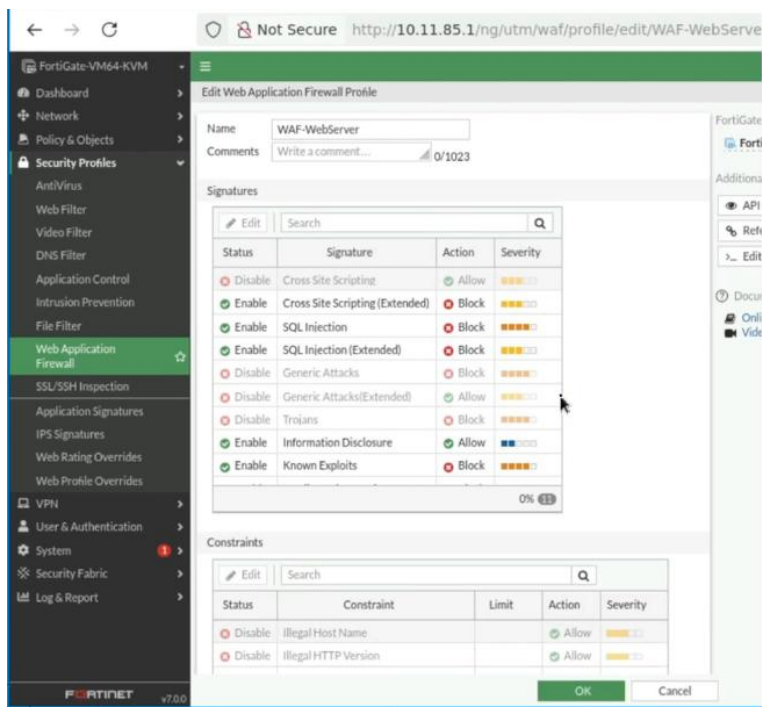
10.11.85.130 icmp_seq=1 timeout
10.11.85.130 icmp_seq=2 timeout
10.11.85.130 icmp_seq=3 timeout
10.11.85.130 icmp_seq=4 timeout
10.11.85.130 icmp_seq=5 timeout

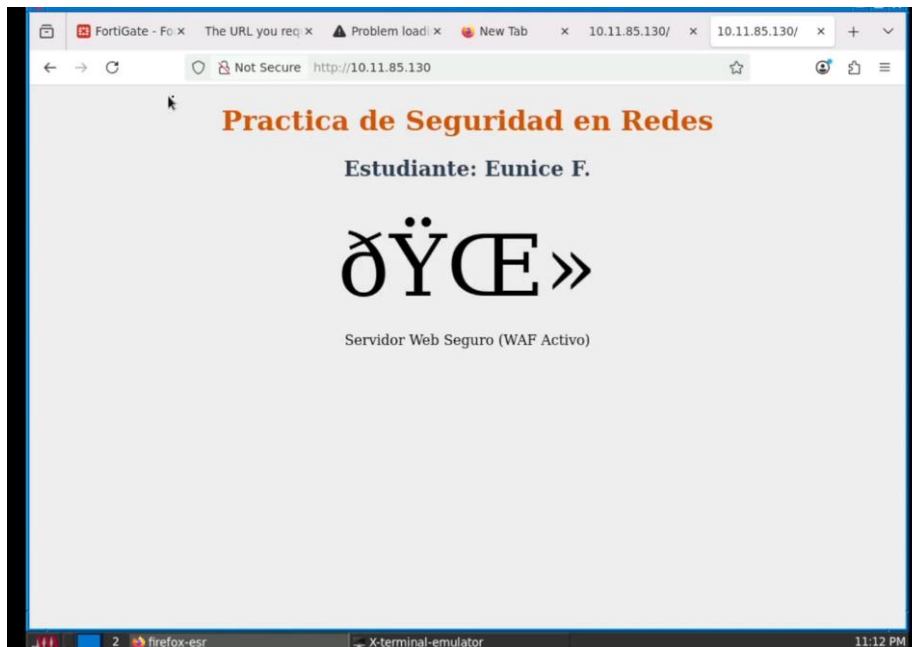
PC1>

```

5.4 WAF sobre el servidor web

El perfil WAF-WebServer, aplicado en la política Usuarios-a-Servidor-HTTP, protege el servicio Apache contra patrones de XSS, SQL Injection y violaciones del protocolo HTTP.





6. Incidencias y lecciones aprendidas

- El bloqueo por categoría de FortiGuard depende de un contrato/licencia activo; para garantizar el bloqueo en un entorno de laboratorio sin licencia, se optó por Static URL Filter.
- Sin un perfil de SSL/SSH Inspection asignado a la política, el Web Filter no tiene visibilidad sobre el dominio solicitado en tráfico HTTPS y el bloqueo no surte efecto.
- Facebook e Instagram pueden evadir la inspección basada en TCP mediante QUIC (HTTP/3 sobre UDP); se mitigó bloqueando la firma QUIC en Application Control.
- El navegador puede mostrar contenido cacheado de una sesión TLS previa aunque el FortiGate ya esté bloqueando correctamente la conexión; se recomienda verificar siempre contra Log & Report antes de descartar una regla como no funcional.